

Welcome to

Introduction to Offensive Security

Saint Cyber – Cyber Akademiet, 2026

Henrik Kramselund he/him han/ham hlk@zencurity.com @kramse

Slides are available as PDF, https://codeberg.org/kramse
academy-2026-day0-intro.tex in the repo security-courses

© license CC BY 3.0. 2026 Henrik Kramselund

Goals for today



- Explain offensive security as an authorised simulation of adversary tools, tactics and techniques
- Distinguish vulnerability scanning, vulnerability management, penetration testing and simulated attack exercises
- Apply the core penetration-testing lifecycle
- Define scope, objectives, testing conditions and rules of engagement before testing
- Assess vulnerability severity using CVSS and prioritise remediation

Plan for today



- What offensive security is – and authorised vs unauthorised
- The three types: vulnerability management & scanning, penetration testing, simulated attack exercises
- CVSS and risk-based prioritisation
- Planning, scope and rules of engagement
- Reporting to technical and management audiences

Hacker – cracker



Short answer – dont discuss this

Yes, originally there was another meaning to hacker, but the media has perverted it and today, and since early 1990s it has meant breaking into stuff for the public

Today a hacker breaks into systems!

Reference. Spafford, Cheswick, Garfinkel, Stoll, . . . - wrote about this and it was lost

Story is interesting and the old meaning is ALSO used in smaller communities, like hacker spaces full of hackers - doing fun and interesting stuff

- *Cuckoo's Egg: Tracking a Spy Through the Maze of Computer Espionage*, Clifford Stoll
- *Hackers: Heroes of the Computer Revolution*, Steven Levy
- *Practical Unix and Internet Security*, Simson Garfinkel, Gene Spafford, Alan Schwartz

Why even do security testing?



Lots of security problems

Pentesting may be a requirement from external partners – example VISA PCI standard

- Boss asking: should we do a security test?
- CIO: hmm, okay
- IT Admins: *sigh* – I know the security sucks in places!
- Its not your systems – dont take the criticism personal, but as an opportunity to get things improved

- Pentest tools are great resources for doing discovery of assets, evaluating the security of large installations quickly – in short using pentest tools makes you more efficient!

Many see the benefits after doing a pentest, so try it!

The three types of offensive security



- Vulnerability management & scanning
- Penetration testing
- Simulated attack exercises

FIXME: one line each on objective and limitation

Benefits of having a planned security test done



Goal of testing is to reduce risk for the systems and secure the organisation from unexpected loss of data, image and increased costs.

Intended audience:

- IT-department and technical personnel
- Management and board
- External auditors, government, financial control VISA/PCI, the public

Output from testing:

- Reports with technical content and recommendations
- Executive summary

Goal is not to find a scape goat to blame – management allocates resources

If security is below in places more resources may be needed.

Planning a pentest



- Scope – what is being tested
- When is the testing done – time frame, wall clock time
- Where are the attacks coming from – log files will contain the attacks
  but other attacks from other sources are likely during the attacks, which must be blocked
- We sometimes go broader than the scope – perhaps checking the router in front with SNMP or doing a small port 80/tcp scan
- Agree if Denial of Service is to be tested
- TL;DR Rules of engagement for the project

Testing Agreement and Scope Example



Usually the scope could include targets like these:

- 192.168.1.1 – firewall/router
- 192.168.1.2 – mail server
- 192.168.1.3 – web server
- Test to be done from monday 1st until friday 5th
- Testing done from 192.0.2.0/28

When testing web servers and sites, especially API – please include hostname, URLs, documentation. If not included some sites and functionality will NOT be tested!

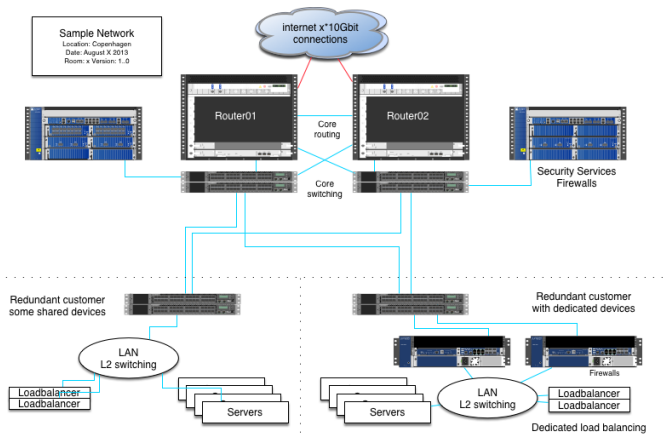
Rules of engagement – rules and ethics for security testing



- NB: big difference between Denmark and other places!
- Security consultant must not be the cause of new vulnerabilities due to the testing
- Security consultant must not install new software on systems without previous agreement
- Security consultant is not to leave insecure system administrator accounts or settings after testing
- Security consultant always contact the customer in case of high-risk vulnerabilities
- It is allowed to peek around in the network – checking if there might be an insecure development or testing server near by
- If you meet other security problems outside of the scope we still report them, but perhaps in an appendix

In general be careful of other people networks and systems

Selecting systems for testing



- Routers on the way to critical systems and networks – especially availability
- Firewall – is the environment protected sufficiently, discarding probes
- Mail servers – relay testing and also critical data
- Web servers – holds data, typically has a lot of functionality
- Cloud systems, storage systems, anywhere data is saved

CVSS – severity scoring



- **FIXME:** what CVSS is and the metric groups
- **FIXME:** exercise – score a current CVE and discuss likelihood x impact

Reporting – results



What is in a pentest report:

- Title, Table of contents, formal report thanks
- Confidentiality agreement – Write "Confidential" on each page
- Executive summary – big companies always want this
- Information about the scan done, what was it
- Scope and targets
- Review of all targets – detailed information and recommendations
- Conclusion – may be more technical
- Appendices – various information, Whois info about subnets and prefixes

BTW When delivering a report, it is up to the organisation to decide which recommendations to implement

Sample report available at: https://github.com/kramse/pentest-report

Summary & references



- Offensive security is authorised, scoped testing that improves the security posture
- Agree scope and rules of engagement first; report for technical and management audiences
- *Web Application Security*, Andrew Hoffman, 2020, ISBN: 9781492053118 (WAS)
- Sample pentest report: https://github.com/kramse/pentest-report